

Principes de cybersécurité, plan de contrôle et de maintenance

1. Introduction

Le Projet Goutte d'eau collecte des données météorologiques (stations SYNOP et capteurs IoT), entraîne un modèle de prévision de pluie (XGBoost) et restitue les prévisions via une API et des interfaces (application mobile, tableau de bord PowerBI).

France Météo étant un établissement public, la protection des données et la continuité de service sont des exigences fortes. Ce document identifie les principaux risques de sécurité du projet, les mesures de protection associées, puis propose un plan de contrôle et de maintenance.

2. Périmètre et données concernées

Les actifs à protéger sont les suivants :

- Données de mesure : relevés des stations et capteurs IoT (température, pluie, pression, humidité).
- Données personnelles : localisation des parcelles et comptes des agriculteurs (soumis au RGPD).
- Modèle entraîné : fichier du modèle (.pkl) et données d'entraînement.
- Services : API de prévision, base de données, tableau de bord PowerBI, application mobile.

3. Risques identifiés

Les risques sont classés par niveau de gravité (Faible / Moyen / Élevé).

Actif	Risque	Gravité
Données IoT	Altération ou falsification des mesures (données faussées en entrée du modèle)	Élevé
Données personnelles	Fuite de la localisation des parcelles / non-conformité RGPD	Élevé
API	Accès non autorisé, injection, absence de limitation de débit (dénier de service)	Élevé
Authentification	Mots de passe faibles, absence de double authentification (MFA)	Moyen
Transport réseau	Interception des échanges (absence de chiffrement HTTPS/TLS)	Moyen
Modèle	Vol du modèle ou empoisonnement des données d'entraînement	Moyen
Base de données	Perte de données (panne, suppression, absence de sauvegarde)	Élevé

4. Mesures de protection

À chaque risque correspond une mesure de réduction :

Risque	Mesure de protection
Altération des mesures IoT	Signature / horodatage des mesures, contrôle de cohérence (valeurs hors plage rejetées)
Fuite de données personnelles	Minimisation et anonymisation des données, chiffrement au repos, consentement RGPD
Accès non autorisé à l'API	Authentification par jeton (JWT), gestion des rôles, journalisation des accès
Déni de service	Limitation de débit (rate-limiting), filtrage des requêtes
Mots de passe faibles	Politique de mots de passe robustes, double authentification (MFA)
Interception réseau	Chiffrement en transit (HTTPS / TLS obligatoire)
Vol du modèle	Stockage sécurisé du modèle, accès restreint, modèle non versionné publiquement
Perte de données	Sauvegardes chiffrées régulières et testées, plan de restauration

5. Plan de contrôle et de maintenance

Ce plan garantit le maintien du niveau de sécurité dans le temps.

5.1. Contrôles récurrents

Action	Fréquence	Responsable
Mise à jour des dépendances et veille des failles (CVE)	Mensuelle	Équipe technique
Revue des accès et des droits utilisateurs	Trimestrielle	Administrateur
Analyse des journaux (logs) et détection d'anomalies	Continue	Équipe technique
Test de restauration des sauvegardes	Trimestrielle	Administrateur
Test d'intrusion (pentest)	Annuelle	Prestataire externe
Audit de conformité RGPD	Annuelle	Référent données

5.2. Gestion des incidents

En cas d'incident de sécurité, la procédure suivante s'applique :

- Détection : alerte via le monitoring ou signalement utilisateur.
- Confinement : isolation du service touché pour limiter la propagation.
- Correction : traitement de la faille et restauration depuis une sauvegarde saine.
- Analyse : recherche de la cause et mesures pour éviter la récurrence.
- Notification : information des personnes concernées et de la CNIL sous 72 h si données personnelles.

5.3. Maintenance

- Maintenance corrective : correction des vulnérabilités et bugs de sécurité identifiés.
- Maintenance préventive : application des correctifs et montées de version régulières.
- Documentation : mise à jour de ce document et du registre des incidents.

6. Synthèse

Le projet présente des risques principalement liés à l'intégrité des données de mesure, à la confidentialité des données personnelles et à la sécurité de l'API. Les mesures proposées (chiffrement, authentification forte, sauvegardes, journalisation) réduisent ces risques. Le plan de contrôle et de maintenance assure le suivi du niveau de sécurité dans la durée, en cohérence avec les obligations d'un établissement public (RGPD, RGAA).